

个人信息保护合规审计管理办法（征求意见稿）

为指导、规范个人信息保护合规审计活动，根据《中华人民共和国个人信息保护法》等法律法规，国家互联网信息办公室起草了《个人信息保护合规审计管理办法（征求意见稿）》，现向社会公开征求意见。公众可以通过以下途径和方式提出反馈意见：1. 登录中华人民共和国司法部

中国政府法制信息网（www.moj.gov.cn、www.chinalaw.gov.cn），进入首页主菜单的“立法意见征集”栏目提出意见。2. 通过电子邮件方式发送至：shujuju@cac.gov.cn。3. 通过信函方式将意见寄至：北京市海淀区阜成路15号国家互联网信息办公室网络数据管理局，邮编100048，并在信封上注明“个人信息保护合规审计管理办法征求意见”。意见反馈截止时间为2023年9月2日。附件：个人信息保护合规审计管理办法（征求意见稿）

国家互联网信息办公室2023年8月3日

个人信息保护合规审计管理办法（征求意见稿）第一条为指导、规范个人信息保护合规审计活动，提高个人信息处理活动合规水平，保护个人信息权益，根据《中华人民共和国个人信息保护法》等法律、行政法规和国家有关规定，制定本办法。第二条个人信息处理者定期开展个人信息保护合规审计，或者按照履行个人信息保护职责的部门要求委托专业机构对其个人信息处理活动进行合规审计，以及对个人信息保护合规审计活动的监督管理适用本办法。第三条本办法所称个人信息保护合规审计，是指对个人信息处理者的个人信息处理活动是否遵守法律、行政法规的情况进行审查和评价的监督活动。第四条处理超过100万人个人信息的个人信息处理者，应当每年至少开展一次个人信息保护合规审计；其他个人信息处理者应当每二年至少开展一次个人信息保护合规审计。第五条个人信息处理者自行开展个人信息保护合规审计，可根据实际情况，由本组织内部机构或者委托专业机构按照本办法要求开展。第六条履行个人信息保护职责的部门在履行职责中，发现个人信息处理活动存在较大风险或者发生个人信息安全事件的，可以要求个人信息处理者委托专业机构对其个人信息处理活动进行合规审计。第七条个人信息处理者按照履行个人信息保护职责的部门要求开展个人信息保护合规审计的，应当在收到通知后尽快按照要求选定专业机构进行个人信息保护合规审计。第八条个人信息处理者按照履行个人信息保护职责的部门要求委托专业机构开展个人信息保护合规审计的，应当保证专业机构能够正常行使下列权限：（一）要求提供或者协助查阅相关文件或资料；（二）进入个人信息处理活动相关场所；（三）观察场所内发生的个人信息处理活动；（四）调查相关业务活动及所依赖的信息系统；（五）检查、测试个人信息处理活动相关设备设施；（六）调取、查阅个人信息处理活动相关数据或信息；（七）访谈与个人信息处理活动有关的人员；（八）就相关问题进行调查、质询和取证；（九）其他开展合规审计工作所必需的权限。第九条个人信息处理者按照履行个人信息保护职责部门要求委托专业机构开展个人信息保护合规审计的，应当在90个工作日内完成个人信息保护合规审计；情况复杂的，报经履行个人信息保护职责的部门批准后可适当延长。第十条个人信息处理者按照履行个人信息保护职责部门要求委托专业机构开展个人信息保护合规审计的，应当按照本办法要求组织实施个人信息保护合规审计，在实施必要合规审计程序后，及时将专业机构出具的个人信息保护合规审计报告报送履行个人信息保护职责的部门。个人信息保护合规审计报告应当由合规审计负责人、专业机构负责人签字并加盖专业机构公章。第十一条个人信息处理者按照履行个人信息保护职责的部门要求委托专业机构开展个人信息保护合规审计的，应当按照专业机构给出的整改建议进行整改，经专业机构复核后将整改情况报送履行个人信息保护职责的部门。第十二条执行个人信息保护合规审计的专业机构应当保持独立性和客观性，连续为同一审计对象开展个人信息保护合规审计不得超过三次。第十三条国家网信部门会同公安机关等国务院有关部门按照统筹规划、合理布局、择优推荐的原则建立个人信息保护合规审计专业机构推荐目录，每年组织开展个人信息保护合规审计专业机构评估评价，并根据评估评价情况动态调整个人信息保护合规审计专业机构推荐目录。鼓励个人信息处理者优先选择推荐目录中的专业机构开展个人信息保护合规审计活动。第十四条专业机构在从事个人信息保护合规审计活动时，应当诚信正直，公正客观地作出合规审计职业判断。专业机构不得转包委托第三方开展个人信息保护合规审计。专业机构在履行个人信息保护合规审计职责中获得的信息，只能用于个人信息保护合规审计的需要，不得用于其他用途；专业机构应当对获得的信息承担保密责任；专业机构应当采取相应技术措施和其他必要措施，保障数据安全。专业机构在履行个人信息保护合规审计职责时不得恶意干扰个人信息处理者的正常经营活动。专业机构有出具虚假、失实报告等违规行为的，个人信息处理者及相关方可向履行个人信息保护职责的部门进行投诉，经履行个人信息保护职责的部门核实的，永久禁止列入个人信息保护合规审计专业机构推荐目录。第十五条违反本办法规定的，依据《中华人民共和国个人信息保护法》等法律法规处理；构成犯罪的，依法追究刑事责任。第十六条本办法由国家互联网信息办公室负责解释，自 年 月 日起施行。附件：个人信息保护合规审计参考要点

个人信息保护合规审计参考要点第一条本要点依据《中华人民共和国个人信息保护法》等法律、行政法规和国家标准的强制性要求制定，为开展个人信息保护合规审计提供参考。第二条个人信息保护合规审计应当首先审查个人信息处理活动的合法性基础条件，重点审查下列事项：（一）处理

个人信息是否取得个人同意，该同意是否在个人信息主体充分知情的前提下自愿、明确作出；（二）基于个人同意处理个人信息，个人信息的处理目的、处理方式和处理的个人信息种类发生变更的，是否重新取得个人同意；（三）基于个人同意处理个人信息，是否为用户提供便捷的撤回同意的方式；（四）基于个人同意处理个人信息，是否对个人同意的操作进行记录；（五）基于个人同意处理个人信息，是否存在以个人不同意处理其个人信息或者撤回同意为由，拒绝提供产品或者服务的情况；处理个人信息属于提供产品或者服务所必需的除外；（六）处理个人信息未取得个人同意，是否属于法律、行政法规规定不需取得个人同意的情形。第三条对个人信息处理规则进行审计时，应当重点审查下列事项：（一）是否真实、准确、完整地告知个人信息处理者的名称或者姓名和联系方式；（二）是否以清单形式列明所收集的个人信息及其处理目的、方式、范围；（三）是否明确个人信息存储期限或者存储期限的确定方法、到期后的处理方式，以及确存储期限为实现处理目的所必要的最短时间；（四）是否明确个人查阅、复制、加工、转移、更正、补充、删除、公开、限制处理个人信息以及注销账号、撤回同意的途径和方法；（五）向第三方提供个人信息的，是否明确向个人告知接收方的名称或者姓名、联系方式、处理目的、处理方式和个人信息的种类，是否取得个人的单独同意；（六）法律、行政法规规定的其他事项。第四条个人信息处理者处理个人信息应当履行告知义务，审计时应当重点审查下列事项：（一）个人信息处理者在处理个人信息前，是否以显著方式、清晰易懂的语言真实、准确、完整地向个人告知个人信息处理规则；（二）告知文本的大小、字体和颜色是否便于个人完整阅读告知事项；（三）线下告知是否通过标注、说明等多种方式向个人履行告知义务；（四）在线告知是否提供文本信息或者通过适当方式向个人履行告知义务；（五）个人信息处理规则发生变更的，是否将变更内容及时告知个人。第五条个人信息处理者存在与他人共同处理个人信息情形的，应当重点审查下列事项：（一）是否约定各自的权利义务；（二）各方采取的个人信息的保护措施；（三）个人信息权益保护机制；（四）个人信息安全事件报告机制；（五）侵害个人信息权益造成损害的，各方应当承担的责任；（六）其他法律、行政法规规定需要约定的权利和义务。第六条个人信息处理者存在委托处理个人信息情形的，应当重点审查下列事项：（一）个人信息处理者在委托处理个人信息前，是否开展个人信息保护影响评估；（二）个人信息处理者与受托人签订的合同，是否约定了委托处理的目的、期限、方式及个人信息的种类、受托人应当采取的技术措施和管理措施、双方的权利义务等；（三）个人信息处理者是否采取定期检查等方式，对受托人的个人信息处理活动进行监督，以确保委托处理个人信息的活动符合法律规定；（四）受托人是否严格按照委托合同的约定处理个人信息，是否存在超出约定的处理目的、处理方式处理个人信息的情况；（五）当委托合同不生效、无效、被撤销或者终止时，受托人是否将个人信息返还个人信息处理者或者予以删除；（六）受托人是否存在转委托他人处理个人信息的情况，是否得到个人信息处理者的同意。第七条个人信息处理者存在因合并、重组、分立、解散、被宣告破产等原因需要转移个人信息情形的，应当重点审查下列事项：（一）个人信息处理者是否向个人告知接收方的名称或者姓名和联系方式；（二）接收方是否继续履行个人信息处理者的义务；（三）接收方变更原先处理目的、处理方式的，是否依照法律、行政法规有关规定重新取得个人同意。第八条个人信息处理者存在向其他个人信息处理者提供其处理的个人信息的，应当重点审查下列事项：（一）是否取得个人的单独同意；（二）是否向个人告知接收方的名称或者姓名、联系方式、处理目的、处理方式和个人信息的种类；（三）接收方是否在双方约定的处理目的、处理方式和个人信息的种类等范围内处理个人信息；（四）变更处理目的、处理方式的，是否依照法律、行政法规规定重新取得个人同意；（五）是否事前进行个人信息保护影响评估。第九条个人信息处理者利用自动化决策处理个人信息的，审计时应当重点评价自动化决策的透明度和结果的公平性、公正性：（一）是否事前主动告知个人自动化决策处理个人信息的种类及可能带来的影响；（二）是否事前对算法模型进行安全评估，并按国家相关规定进行备案，以尽可能减少自动化决策算法模型存在的缺陷，当应用场景和主要功能发生变化时，是否对算法模型重新进行评估；（三）是否事前对算法模型进行科技伦理审查；（四）是否事前进行个人信息保护影响评估；（五）是否向用户提供保障机制，以使用户可以通过便捷方式拒绝通过自动化决策方式作出对个人权益有重大影响的决定，或要求个人信息处理者就应用自动化决策方式作出对用户个人权益有重大影响的决定予以说明；（六）是否向用户提供删除或者修改用于自动化决策服务的针对其个人特征的用户标签功能；（七）是否采取必要措施对算法和参数模型进行保护；（八）是否对个人信息处理、标签管理、模型训练等自动化决策过程中的人工操作进行记录，防范人为恶意操纵自动化决策信息和结果；（九）向个人进行信息推送、商业营销时，是否同时提供不针对个人特征的选项，或者提供便捷的拒绝自动化决策服务的方式；（十）是否采取了有效措施，防止自动化决策根据消费者的偏好、交易习惯等对人在交易条件上实行不合理的差别待遇；（十一）其他可能影响自动化决策的透明度和结果公平、公正的事项。第十条个人信息处理者存在公开其处理的个人信息情形的，应当重点审查下列事项：（一）个人信息处理者公开其处理的个人信息前是否取得个人单独同意，该授权是否真实、有效，是否存在违背个人意愿将个人信息予以公开的情况；（二）个人信息处理者公开个人信息前，是否进行了个人信息保护影响评估。第十一条个人信息处理者在公共场所安装图像采集、个人身份识别设备的，应当重点对其安装图像采集、个人信息身份识别设备的合法性及所

收集个人信息的用途进行审查。审查内容包括但不限于：（一）是否为维护公共安全所必需，是否存在为商业目的处理所采集信息的情况；（二）是否设置了显著的提示标志；（三）若个人信息处理者所收集的图像、身份识别信息用于维护公共安全以外用途的，是否取得个人单独同意。第十二条个人信息处理者处理已公开个人信息的，审计时应当重点审查个人信息处理者是否存在下列违规行为：（一）向已公开个人信息中的电子邮箱、手机号等发送与其公开目的无关的信息；（二）利用已公开的个人信息从事网络暴力活动；（三）处理个人明确拒绝处理的已公开个人信息；（四）未取得个人同意处理已公开的个人信息对个人权益造成重大影响。第十三条个人信息处理者处理敏感个人信息的，审计时应当重点审查下列事项：（一）处理生物识别、宗教信仰、特定身份、医疗健康、金融账户、行踪轨迹等敏感个人信息的，是否事前取得个人的单独同意；（二）处理不满十四周岁未成年人的个人信息，是否事前取得未成年人的父母或者其他监护人的同意；（三）处理敏感个人信息的目的、方式是否合法、正当、必要；（四）敏感个人信息处理是否与提供商品或者服务、履行法定职责或者法定义务等特定的目的密切相关，是否以非必要不处理为原则；（五）是否在事前进行个人信息保护影响评估，并向个人告知处理敏感个人信息的必要性以及对个人权益的影响；（六）法律、行政法规规定应当取得书面同意的，是否取得书面同意；（七）是否对处理敏感个人信息的过程进行了记录，以保障处理敏感个人信息流程合法合规。第十四条个人信息处理者业务涉及处理不满十四周岁未成年人个人信息的，审计时应当重点审查下列事项：（一）是否制定专门的未成年人个人信息处理规则；（二）是否向未成年人及其监护人告知未成年人个人信息的处理目的、处理方式、处理必要性及处理个人信息的种类、所采取的保护措施等；（三）是否存在强制要求未成年人或者其监护人同意非必要的个人信息处理的行为。第十五条个人信息处理者存在向境外提供个人信息情形的，应当重点审查下列事项：（一）关键信息基础设施运营者和处理100万人以上个人信息的个人信息处理者向境外提供个人信息是否经过国家网信部门组织的安全评估；（二）自上年1月1日起累计向境外提供10万人个人信息或者1万人敏感个人信息的个人信息处理者向境外提供个人信息是否经过国家网信部门组织的安全评估；（三）是否存在向外国司法或者执法机构提供存储于中华人民共和国境内的个人信息的情形，若有，是否经过中华人民共和国主管机关批准；（四）中华人民共和国缔结或者参加的国际条约、协定对向中华人民共和国境外提供个人信息的条件等有规定的，是否按照其规定执行；（五）是否按照国家网信部门的规定，经专业机构进行个人信息保护认证或者按照国家网信部门制定的标准合同与境外接收方签订合同，或者符合法律、行政法规、国家网信部门规定的其他条件；（六）是否了解境外接收方所在国家或者地区的个人信息保护政策和网络安全环境对出境个人信息的影响；（七）是否存在违规向被列入限制或者禁止个人信息提供清单的组织和个人提供个人信息的情形。第十六条个人信息处理者向境外提供个人信息，应当采取必要措施，保障境外接收方处理个人信息的活动达到《中华人民共和国个人信息保护法》规定的个人信息保护标准。审计时应当重点审查个人信息处理者对境外接收方采取监督措施的有效性，包括但不限于：（一）是否了解和掌握境外接收方的情况，特别是接收方是否具备必要的个人信息保护能力；（二）是否向境外接收方告知我国法律、行政法规对个人信息保护的要求，并要求境外接收方采取相应的保护措施；（三）是否采取签订协议、定期核查等方式，督促境外接收方切实履行个人信息保护义务。第十七条对个人信息删除权保障情况进行审计时，应当重点审查下列情形个人信息删除的情况：（一）个人信息处理目的已实现、无法实现或者为实现处理目的不再必要；（二）停止提供产品或者服务，或者个人注销账号；（三）达到与个人约定的存储期限；（四）个人撤回同意；（五）因使用自动化采集技术等，无法避免采集到非必要个人信息或者未经同意的个人信息；（六）个人信息处理者违反法律、行政法规或者违反约定处理个人信息。法律、行政法规规定的保存期限未届满，或者删除个人信息从技术上难以实现的，个人信息处理者应当停止除存储和采取必要的安全措施之外的处理。第十八条个人信息处理者应当保障个人行使个人信息权益的权利，审计时应当重点审查下列事项：（一）是否建立个人行使权利的申请受理机制；（二）是否向个人提供便捷的查阅、复制、转移、更正、补充、删除个人信息的方法；（三）是否及时响应个人行使权利的申请，是否及时、完整、准确告知处理意见或者执行结果。第十九条个人信息处理者应当响应个人申请，对其个人信息处理规则进行解释说明，审计时应当重点对下列内容进行评价：（一）个人信息处理者是否提供便捷的方式和途径，接受、处理个人关于个人信息处理规则解释说明的要求；（二）接到个人的要求后，个人信息处理者是否在合理的时间内，使用通俗易懂的语言对其个人信息处理规则作出解释说明。第二十条个人信息处理者对个人信息保护承担主体责任，审计时应当重点对个人信息处理者履行主体责任情况进行评价，包括但不限于下列事项：（一）个人信息保护制度制定、组织架构、管理程序与处理个人信息的性质、规模、复杂程度、风险程度的适应性；（二）个人信息保护职责分工是否合理、职责是否明确、报告关系是否清晰；（三）个人信息处理者为个人信息保护提供的人、财、物保障与企业业务规模、运营计划、个人信息合规风险管理的匹配性。第二十一条个人信息处理者应当依照法律、行政法规的规定制定内部管理制度和操作规程，明确组织架构、岗位职责，建立工作流程、完善内控制度，保障个人信息处理合规与安全。审计时，应当重点对个人信息处理者个人信息保护内部管理制度和操作规程进行审查，包括但不限于：（一）个人信息保护工作的方针、目标、原则是否符合法律、行政法规规定；（二）个人信

息保护组织架构、人员配备、行为规范、管理责任是否与应当履行的个人信息保护责任相适应；（三）是否根据个人信息的种类、来源、敏感程度、用途等，对个人信息进行分类，并采取有针对性的管理或者安全技术措施；（四）是否建立个人信息安全事件应急响应机制；（五）是否建立个人信息保护影响评估、合规审计制度；（六）是否建立畅通的个人信息保护投诉举报受理流程；（七）是否制定实施个人信息保护安全教育和培训计划；（八）是否建立个人信息保护负责人及相关人员履职评价制度；（九）是否建立针对个人信息处理相关人员的个人信息违规处置或者违规行为责任制度，并有效实施；（十）法律、行政法规规定的其他内容。第二十二條个人信息处理者应当采取与所处理个人信息规模、类型相适应的安全技术措施，并对个人信息处理者采取的技术措施的有效性进行评价，评价内容包括但不限于：（一）是否参照有关国家标准或者技术要求，采取相应安全技术措施实现个人信息的保密性、完整性、可用性；（二）是否采取加密、去标识化等安全技术措施，确保在不借助额外信息的情况下，消除或者降低个人信息的可识别性；（三）采取的安全技术措施能否合理确定有关人员查阅、复制、传输等个人信息的操作权限，减少个人信息在处理过程中未经授权的访问和滥用风险。第二十三條对个人信息处理者教育培训计划的制定和实施情况进行审计时，应当重点对下列事项进行评价：（一）是否按计划对管理人员、技术人员、操作人员、全员开展相应的安全教育和培训，是否对相应人员的个人信息保护意识和技能进行考核；（二）培训内容、培训方式、培训对象、培训频率等能否满足个人信息保护需要。第二十四條处理个人信息达到国家网信部门规定数量的个人信息处理者应当指定个人信息保护负责人，对个人信息处理活动的合规性负责。审计时，应当重点审查下列事项：（一）个人信息保护负责人是否具有相关的工作经历和专业知識，熟悉个人信息保护相关法律、行政法规；（二）个人信息保护负责人是否具有明确清晰的职责，是否被赋予充分的权限协调组织内个人信息处理相关部门与人员；（三）个人信息保护负责人是否有权提名个人信息保护团队负责人，并与其保持顺畅的沟通和联系；（四）个人信息保护负责人在个人信息处理重大事项决策前是否有权提出相关意见和建议；（五）个人信息保护负责人是否有权对组织内部个人信息处理的不合规操作进行制止和采取必要的纠正措施；（六）个人信息处理者是否公开个人信息保护负责人的联系方式，并将个人信息保护负责人的姓名、联系方式等报送履行个人信息保护职责的部门。第二十五條对个人信息处理者开展个人信息保护影响评估情况进行审计时，应当重点对影响评估开展情况和评估内容进行审查：（一）是否依照法律、行政法规的规定，在进行对个人权益具有重大影响的个人信息处理活动前通过个人信息保护影响评估；（二）是否对个人处理活动的合法性、正当性和必要性进行了分析评估，是否存在过度收集个人信息的情况；（三）是否对限制个人自主决定权、引发差别性待遇、导致个人名誉受损或者遭受精神压力、造成人身财产受损等安全风险进行了分析评估；（四）是否对所采取的保护措施的合法性、有效性、适应性进行了分析评估；（五）个人信息保护影响评估报告和处理记录是否至少保存三年。第二十六條个人信息处理者应当制定个人信息安全事件应急预案。审计时，应当对应急预案的全面性、有效性、可执行性作出评价，包括但不限于以下内容：（一）是否结合业务实际，对面临的个人信息安全风险作出了系统评估和预测；（二）指导思想、基本策略，组织机构、人员，技术、物资保障及指挥处置程序、应急和支持措施等是否足以应对预测的风险；（三）是否对相关人员进行应急预案培训，定期对应急预案进行演练。第二十七條对个人信息处理者个人信息安全事件应急响应处置情况进行评价时，应当重点考虑下列因素：（一）是否按照应急预案、操作规程及时查明个人信息安全事件的影响、范围和可能造成的危害，分析、确定事件发生的原因，提出防止危害扩大的措施方案；（二）是否建立通报渠道，能否在事件发生后72小时内通知履行个人信息保护职责的部门和个人；（三）是否采取相应措施将个人信息安全事件可能造成的损失和可能产生的危害风险降低到最小。第二十八條大型互联网平台运营者应当成立主要由外部成员组成的独立机构对个人信息保护情况进行监督。审计时，应当对独立机构的独立性、履职能力、监督作用等进行评价。（一）评价独立机构对个人信息保护情况进行监督的独立性，重点审查外部成员与个人信息处理者及其主要股东是否存在可能妨碍其进行独立客观判断的关系；（二）评价外部成员的履职能力，重点审查外部成员是否具备相应的专业知识、能力和经验，能否对个人信息处理者的个人信息保护情况进行监督、指导，发表客观公正的意见建议；（三）评价独立机构的监督作用，重点审查独立机构在个人信息处理者合规制度体系建设、平台规则制定、重大个人信息安全事件处置、督促企业履行社会责任等方面发挥的作用。第二十九條针对大型互联网平台规则，应当重点审计下列事项：（一）评价平台规则的合法合规性，是否存在与法律、行政法规相抵触的情况；（二）评价平台规则的公平公正性，是否存在恶意竞争、影响消费者权益等违反公平竞争原则、诚实信用原则、公序良俗的内容；（三）评价平台规则个人信息保护条款的有效性，是否合理界定了平台、平台内产品或者服务提供者的个人信息保护权利和义务，是否对平台内经营者处理个人信息行为进行规范，平台内经营者的个人信息保护义务是否明确；（四）检查平台规则的执行情况，通过抽样等方式验证平台规则是否被有效执行。第三十條大型互联网平台运营者应当对其平台内产品或者服务提供者的个人信息处理活动进行监督。审计时，应当重点审查下列事项：（一）是否定期审核平台内产品或者服务提供者个人信息处理规则的合法性、合理性；（二）是否定期对平台内产品或者服务提供者处理个人信息遵守法律、行政法规情况进行审核；（三）对于严重违法法律、行政法规处理个人信息的

产品或者服务提供者，平台是否及时停止向其提供服务。第三十一条大型互联网平台运营者应当每年发布个人信息保护社会责任报告。审计时，应当重点审查社会责任报告下列内容的披露情况：（一）个人信息保护组织架构和内部管理情况；（二）个人信息保护能力建设情况；（三）个人信息保护措施和成效；（四）个人行使权利的受理情况；（五）独立监督机构履职情况；（六）重大个人信息安全事件处理情况；（七）法律、行政法规规定的其他情况。

为指导、规范个人信息保护合规审计活动，根据《中华人民共和国个人信息保护法》等法律法规，国家互联网信息办公室起草了《个人信息保护合规审计管理办法（征求意见稿）》，现向社会公开征求意见。公众可以通过以下途径和方式提出反馈意见：

1. 登录中华人民共和国司法部

中国政府法制信息网（www.moj.gov.cn、www.chinalaw.gov.cn），进入首页主菜单的“立法意见征集”栏目提出意见。

2. 通过电子邮件方式发送至：shujuju@cac.gov.cn。

3. 通过信函方式将意见寄至：北京市海淀区阜成路15号国家互联网信息办公室网络数据管理局，邮编100048，并在信封上注明“个人信息保护合规审计管理办法征求意见”。

意见反馈截止时间为2023年9月2日。

附件：个人信息保护合规审计管理办法（征求意见稿）

个人信息保护合规审计管理办法

第一条为指导、规范个人信息保护合规审计活动，提高个人信息处理活动合规水平，保护个人信息权益，根据《中华人民共和国个人信息保护法》等法律、行政法规和国家有关规定，制定本办法。

第二条个人信息处理者定期开展个人信息保护合规审计，或者按照履行个人信息保护职责的部门要求委托专业机构对其个人信息处理活动进行合规审计，以及对个人信息保护合规审计活动的监督管理适用本办法。

第三条本办法所称个人信息保护合规审计，是指对个人信息处理者的个人信息处理活动是否遵守法律、行政法规的情况进行审查和评价的监督活动。

第四条处理超过100万人个人信息的个人信息处理者，应当每年至少开展一次个人信息保护合规审计；其他个人信息处理者应当每二年至少开展一次个人信息保护合规审计。

第五条个人信息处理者自行开展个人信息保护合规审计，可根据实际情况，由本组织内部机构或者委托专业机构按照本办法要求开展。

第六条履行个人信息保护职责的部门在履行职责中，发现个人信息处理活动存在较大风险或者发生个人信息安全事件的，可以要求个人信息处理者委托专业机构对其个人信息处理活动进行合规审计。

第七条个人信息处理者按照履行个人信息保护职责的部门要求开展个人信息保护合规审计的，应当在收到通知后尽快按照要求选定专业机构进行个人信息保护合规审计。

第八条个人信息处理者按照履行个人信息保护职责的部门要求委托专业机构开展个人信息保护合规审计的，应当保证专业机构能够正常行使下列权限：

- （一）要求提供或者协助查阅相关文件或资料；
- （二）进入个人信息处理活动相关场所；
- （三）观察场所内发生的个人信息处理活动；
- （四）调查相关业务活动及所依赖的信息系统；
- （五）检查、测试个人信息处理活动相关设备设施；
- （六）调取、查阅个人信息处理活动相关数据或信息；
- （七）访谈与个人信息处理活动有关的人员；
- （八）就相关问题进行调查、质询和取证；
- （九）其他开展合规审计工作所必需的权限。

第九条个人信息处理者按照履行个人信息保护职责部门要求委托专业机构开展个人信息保护合规审计的，应当在90个工作日内完成个人信息保护合规审计；情况复杂的，报经履行个人信息保护职责的部门批准后可适当延长。

第十条个人信息处理者按照履行个人信息保护职责部门要求委托专业机构开展个人信息保护合规审计的，应当按照本办法要求组织实施个人信息保护合规审计，在实施必要合规审计程序后，及时将专业机构出具的个人信息保护合规审计报告报送履行个人信息保护职责的部门。个人信息保护合规审计报告应当由合规审计负责人、专业机构负责人签字并加盖专业机构公章。

第十一条个人信息处理者按照履行个人信息保护职责的部门要求委托专业机构开展个人信息保护合规审计的，应当按照专业机构给出的整改建议进行整改，经专业机构复核后将整改情况报送履行个人信息保护职责的部门。

第十二条执行个人信息保护合规审计的专业机构应当保持独立性和客观性，连续为同一审计对象开展个人信息保护合规审计不得超过三次。

第十三条国家网信部门会同公安机关等国务院有关部门按照统筹规划、合理布局、择优推荐的原则建立个人信息保护合规审计专业机构推荐目录，每年组织开展个人信息保护合规审计专业机构评估评价，并根据评估评价情况动态调整个人信息保护合规审计专业机构推荐目录。

鼓励个人信息处理者优先选择推荐目录中的专业机构开展个人信息保护合规审计活动。

第十四条专业机构在从事个人信息保护合规审计活动时，应当诚信正直，公正客观地作出合规审计职业判断。

专业机构不得转包委托第三方开展个人信息保护合规审计。

专业机构在履行个人信息保护合规审计职责中获得的信息，只能用于个人信息保护合规审计的需要，不得用于其他用途；专业机构应当对获得的信息承担保密责任；专业机构应当采取相应技术措施和其他必要措施，保障数据安全。

专业机构在履行个人信息保护合规审计职责时不得恶意干扰个人信息处理者的正常经营活动。

专业机构有出具虚假、失实报告等违规行为的，个人信息处理者及相关方可向履行个人信息保护职责的部门进行投诉，经履行个人信息保护职责的部门核实的，永久禁止列入个人信息保护合规审计专业机构推荐目录。

第十五条违反本办法规定的，依据《中华人民共和国个人信息保护法》等法律法规处理；构成犯罪的，依法追究刑事责任。

第十六条本办法由国家互联网信息办公室负责解释，自 年 月 日起施行。

附件：个人信息保护合规审计参考要点

个人信息保护合规审计参考要点

第一条本要点依据《中华人民共和国个人信息保护法》等法律、行政法规和国家标准的强制性要求制定，为开展个人信息保护合规审计提供参考。

第二条个人信息保护合规审计应当首先审查个人信息处理活动的合法性基础条件，重点审查下列事项：

- （一）处理个人信息是否取得个人同意，该同意是否在个人信息主体充分知情的前提下自愿、明确作出；
- （二）基于个人同意处理个人信息，个人信息的处理目的、处理方式和处理的个人信息种类发生变更的，是否重新取得个人同意；
- （三）基于个人同意处理个人信息，是否为个人提供便捷的撤回同意的方式；
- （四）基于个人同意处理个人信息，是否对个人同意的操作进行记录；
- （五）基于个人同意处理个人信息，是否存在以个人不同意处理其个人信息或者撤回同意为由，拒绝提供产品或者服务的情况；处理个人信息属于提供产品或者服务所必需的除外；
- （六）处理个人信息未取得个人同意，是否属于法律、行政法规规定不需取得个人同意的情形。

第三条对个人信息处理规则进行审计时，应当重点审查下列事项：

- （一）是否真实、准确、完整地告知个人信息处理者的名称或者姓名和联系方式；
- （二）是否以清单形式列明所收集的个人信息及其处理目的、方式、范围；
- （三）是否明确个人信息存储期限或者存储期限的确定方法、到期后的处理方式，以及确存储期限为实现处理目

的所必要的最短时间；

（四）是否明确个人查阅、复制、加工、转移、更正、补充、删除、公开、限制处理个人信息以及注销账号、撤回同意的途径和方法；

（五）向第三方提供个人信息的，是否明确向个人告知接收方的名称或者姓名、联系方式、处理目的、处理方式和个人信息的种类，是否取得个人的单独同意；

（六）法律、行政法规规定的其他事项。

第四条个人信息处理者处理个人信息应当履行告知义务，审计时应当重点审查下列事项：

（一）个人信息处理者在处理个人信息前，是否以显著方式、清晰易懂的语言真实、准确、完整地向个人告知个人信息处理规则；

（二）告知文本的大小、字体和颜色是否便于个人完整阅读告知事项；

（三）线下告知是否通过标注、说明等多种方式向个人履行告知义务；

（四）在线告知是否提供文本信息或者通过适当方式向个人履行告知义务；

（五）个人信息处理规则发生变更的，是否将变更内容及时告知个人。

第五条个人信息处理者存在与他人共同处理个人信息情形的，应当重点审查下列事项：

（一）是否约定各自的权利义务；

（二）各方采取的个人信保护息措施；

（三）个人信息权益保护机制；

（四）个人信息安全事件报告机制；

（五）侵害个人信息权益造成损害的，各方应当承担的责任；

（六）其他法律、行政法规规定需要约定的权利和义务。

第六条个人信息处理者存在委托处理个人信息情形的，应当重点审查下列事项：

（一）个人信息处理者在委托处理个人信息前，是否开展个人信息保护影响评估；

（二）个人信息处理者与受托人签订的合同，是否约定了委托处理的目的、期限、方式及个人信息的种类、受托人应当采取的技术措施和管理措施、双方的权利义务等；

（三）个人信息处理者是否采取定期检查等方式，对受托人的个人信息处理活动进行监督，以确保委托处理个人信息的活动符合法律规定；

（四）受托人是否严格按照委托合同的约定处理个人信息，是否存在超出约定的处理目的、处理方式处理个人信息的情况；

（五）当委托合同不生效、无效、被撤销或者终止时，受托人是否将个人信息返还个人信息处理者或者予以删除；

（六）受托人是否存在转委托他人处理个人信息的情况，是否得到个人信息处理者的同意。

第七条个人信息处理者存在因合并、重组、分立、解散、被宣告破产等原因需要转移个人信息情形的，应当重点审查下列事项：

（一）个人信息处理者是否向个人告知接收方的名称或者姓名和联系方式；

（二）接收方是否继续履行个人信息处理者的义务；

（三）接收方变更原先处理目的、处理方式的，是否依照法律、行政法规有关规定重新取得个人同意。

第八条个人信息处理者存在向其他个人信息处理者提供其处理的个人信息的，应当重点审查下列事项：

（一）是否取得个人的单独同意；

（二）是否向个人告知接收方的名称或者姓名、联系方式、处理目的、处理方式和个人信息的种类；

（三）接收方是否在双方约定的处理目的、处理方式和个人信息的种类等范围内处理个人信息；

（四）变更处理目的、处理方式的，是否依照法律、行政法规规定重新取得个人同意；

（五）是否事前进行个人信息保护影响评估。

第九条个人信息处理者利用自动化决策处理个人信息的，审计时应当重点评价自动化决策的透明度和结果的公平性、公正性：

（一）是否事前主动告知个人自动化决策处理个人信息的种类及可能带来的影响；

（二）是否事前对算法模型进行安全评估，并按国家相关规定进行备案，以尽可能减少自动化决策算法模型存在的缺陷，当应用场景和主要功能发生变化时，是否对算法模型重新进行评估；

（三）是否事前对算法模型进行科技伦理审查；

（四）是否事前进行个人信息保护影响评估；

（五）是否向用户提供保障机制，以便用户可以通过便捷方式拒绝通过自动化决策方式作出对个人权益有重大影响的决定，或要求个人信息处理者就应用自动化决策方式作出对用户个人权益有重大影响的决定予以说明；

（六）是否向用户提供删除或者修改用于自动化决策服务的针对其个人特征的用户标签功能；

（七）是否采取必要措施对算法和参数模型进行保护；

（八）是否对个人信息处理、标签管理、模型训练等自动化决策过程中的人工操作进行记录，防范人为恶意操纵自动化决策信息和结果；

（九）向个人进行信息推送、商业营销时，是否同时提供不针对个人特征的选项，或者提供便捷的拒绝自动化决策服务的方式；

（十）是否采取了有效措施，防止自动化决策根据消费者的偏好、交易习惯等对个人在交易条件上实行不合理的差别待遇；

（十一）其他可能影响自动化决策的透明度和结果公平、公正的事项。

第十条个人信息处理者存在公开其处理的个人信息情形的，应当重点审查下列事项：

（一）个人信息处理者公开其处理的个人信息前是否取得个人单独同意，该授权是否真实、有效，是否存在违背个人意愿将个人信息予以公开的情况；

（二）个人信息处理者公开个人信息前，是否进行了个人信息保护影响评估。

第十一条个人信息处理者在公共场所安装图像采集、个人身份识别设备的，应当重点对其安装图像采集、个人信息身份识别设备的合法性及所收集个人信息的用途进行审查。审查内容包括但不限于：

（一）是否为维护公共安全所必需，是否存在为商业目的处理所采集信息的情况；

（二）是否设置了显著的提示标志；

（三）若个人信息处理者所收集的图像、身份识别信息用于维护公共安全以外用途的，是否取得个人单独同意。

第十二条个人信息处理者处理已公开个人信息的，审计时应当重点审查个人信息处理者是否存在下列违规行为：

（一）向已公开个人信息中的电子邮箱、手机号等发送与其公开目的无关的信息；

（二）利用已公开的个人信息从事网络暴力活动；

（三）处理个人明确拒绝处理的已公开个人信息；

（四）未取得个人同意处理已公开的个人信息对个人权益造成重大影响。

第十三条个人信息处理者处理敏感个人信息的，审计时应当重点审查下列事项：

（一）处理生物识别、宗教信仰、特定身份、医疗健康、金融账户、行踪轨迹等敏感个人信息的，是否事前取得个人的单独同意；

（二）处理不满十四周岁未成年人的个人信息，是否事前取得未成年人的父母或者其他监护人的同意；

（三）处理敏感个人信息的目的、方式是否合法、正当、必要；

（四）敏感个人信息处理是否与提供商品或者服务、履行法定职责或者法定义务等特定的目的密切相关，是否以非必要不处理为原则；

- (五) 是否在事前进行个人信息保护影响评估,并向个人告知处理敏感个人信息的必要性以及对个人权益的影响;
- (六) 法律、行政法规规定应当取得书面同意的,是否取得书面同意;
- (七) 是否对处理敏感个人信息的过程进行了记录,以保障处理敏感个人信息流程合法合规。

第十四条个人信息处理者业务涉及处理不满十四周岁未成年人个人信息的,审计时应当重点审查下列事项:

- (一) 是否制定专门的未成年人个人信息处理规则;
- (二) 是否向未成年人及其监护人告知未成年人个人信息的处理目的、处理方式、处理必要性及处理个人信息的种类、所采取的保护措施等;
- (三) 是否存在强制要求未成年人或者其监护人同意非必要的个人信息处理的行为。

第十五条个人信息处理者存在向境外提供个人信息情形的,应当重点审查下列事项:

- (一) 关键信息基础设施运营者和处理100万人以上个人信息的个人信息处理者向境外提供个人信息是否经过国家网信部门组织的安全评估;
- (二) 自上年1月1日起累计向境外提供10万人个人信息或者1万人敏感个人信息的个人信息处理者向境外提供个人信息是否经过国家网信部门组织的安全评估;
- (三) 是否存在向外国司法或者执法机构提供存储于中华人民共和国境内的个人信息的情形,若有,是否经过中华人民共和国主管机关批准;
- (四) 中华人民共和国缔结或者参加的国际条约、协定对向中华人民共和国境外提供个人信息的条件等有规定的,是否按照其规定执行;
- (五) 是否按照国家网信部门的规定,经专业机构进行个人信息保护认证或者按照国家网信部门制定的标准合同与境外接收方签订合同,或者符合法律、行政法规、国家网信部门规定的其他条件;
- (六) 是否了解境外接收方所在国家或者地区的个人信息保护政策和网络安全环境对出境个人信息的影响;
- (七) 是否存在违规向被列入限制或者禁止个人信息提供清单的组织和个人提供个人信息的情形。

第十六条个人信息处理者向境外提供个人信息,应当采取必要措施,保障境外接收方处理个人信息的活动达到《中华人民共和国个人信息保护法》规定的个人信息保护标准。审计时应当重点审查个人信息处理者对境外接收方采取监督措施的有效性,包括但不限于:

- (一) 是否了解和掌握境外接收方的情况,特别是接收方是否具备必要的个人信息保护能力;
- (二) 是否向境外接收方告知我国法律、行政法规对个人信息保护的要求,并要求境外接收方采取相应的保护措施;
- (三) 是否采取签订协议、定期核查等方式,督促境外接收方切实履行个人信息保护义务。

第十七条对个人信息删除权保障情况进行审计时,应当重点审查下列情形个人信息删除的情况:

- (一) 个人信息处理目的已实现、无法实现或者为实现处理目的不再必要;
- (二) 停止提供产品或者服务,或者个人注销账号;
- (三) 达到与个人约定的存储期限;
- (五) 因使用自动化采集技术等,无法避免采集到非必要个人信息或者未经同意的个人信息;
- (六) 个人信息处理者违反法律、行政法规或者违反约定处理个人信息。

法律、行政法规规定的保存期限未届满,或者删除个人信息从技术上难以实现的,个人信息处理者应当停止除存储和采取必要的安全措施之外的处理。

第十八条个人信息处理者应当保障个人行使个人信息权益的权利,审计时应当重点审查下列事项:

- (一) 是否建立个人行使权利的申请受理机制;
- (二) 是否向个人提供便捷的查阅、复制、转移、更正、补充、删除个人信息的方法;
- (三) 是否及时响应个人行使权利的申请,是否及时、完整、准确告知处理意见或者执行结果。

第十九条个人信息处理者应当响应个人申请,对其个人信息处理规则进行解释说明,审计时应当重点对下列内容进

行评价：

- （一）个人信息处理者是否提供便捷的方式和途径，接受、处理个人关于个人信息处理规则解释说明的要求；
- （二）接到个人的要求后，个人信息处理者是否在合理的时间内，使用通俗易懂的语言对其个人信息处理规则作出解释说明。

第二十条个人信息处理者对个人信息保护承担主体责任，审计时应当重点对个人信息处理者履行主体责任情况进行评价，包括但不限于下列事项：

- （一）个人信息保护制度制定、组织架构、管理程序与处理个人信息的性质、规模、复杂程度、风险程度的适应性；
- （二）个人信息保护职责分工是否合理、职责是否明确、报告关系是否清晰；
- （三）个人信息处理者为个人信息保护提供的人、财、物保障与企业业务规模、运营计划、个人信息合规风险管理的匹配性。

第二十一条个人信息处理者应当依照法律、行政法规的规定制定内部管理制度和操作规程，明确组织架构、岗位职责，建立工作流程、完善内控制度，保障个人信息处理合规与安全。审计时，应当重点对个人信息处理者个人信息保护内部管理制度和操作规程进行审查，包括但不限于：

- （一）个人信息保护工作的方针、目标、原则是否符合法律、行政法规规定；
- （二）个人信息保护组织架构、人员配备、行为规范、管理责任是否与应当履行的个人信息保护责任相适应；
- （三）是否根据个人信息的种类、来源、敏感程度、用途等，对个人信息进行分类，并采取有针对性的管理或者安全技术措施；
- （四）是否建立个人信息安全事件应急响应机制；
- （五）是否建立个人信息保护影响评估、合规审计制度；
- （六）是否建立畅通的个人信息保护投诉举报受理流程；
- （七）是否制定实施个人信息保护安全教育和培训计划；
- （八）是否建立个人信息保护负责人及相关人员履职评价制度；
- （九）是否建立针对个人信息处理相关人员的个人信息违规处置或者违规行为责任制度，并有效实施；
- （十）法律、行政法规规定的其他内容。

第二十二条个人信息处理者应当采取与所处理个人信息规模、类型相适应的安全技术措施，并对个人信息处理者采取的技术措施的有效性进行评价，评价内容包括但不限于：

- （一）是否参照有关国家标准或者技术要求，采取相应安全技术措施实现个人信息的保密性、完整性、可用性；
- （二）是否采取加密、去标识化等安全技术措施，确保在不借助额外信息的情况下，消除或者降低个人信息的可识别性；
- （三）采取的安全技术措施能否合理确定有关人员查阅、复制、传输等个人信息的操作权限，减少个人信息在处理过程中未经授权的访问和滥用风险。

第二十三条对个人信息处理者教育培训计划的制定和实施情况进行审计时，应当重点对下列事项进行评价：

- （一）是否按计划对管理人员、技术人员、操作人员、全员开展相应的安全教育和培训，是否对相应人员的个人信息保护意识和技能进行考核；
- （二）培训内容、培训方式、培训对象、培训频率等能否满足个人信息保护需要。

第二十四条处理个人信息达到国家网信部门规定数量的个人信息处理者应当指定个人信息保护负责人，对个人信息处理活动的合规性负责。审计时，应当重点审查下列事项：

- （一）个人信息保护负责人是否具有相关的工作经历和专业知识，熟悉个人信息保护相关法律、行政法规；
- （二）个人信息保护负责人是否具有明确清晰的职责，是否被赋予充分的权限协调组织内个人信息处理相关部门与人员；

- (三) 个人信息保护负责人是否有权提名个人信息保护团队负责人，并与其保持顺畅的沟通和联系；
- (四) 个人信息保护负责人在个人信息处理重大事项决策前是否有权提出相关意见和建议；
- (五) 个人信息保护负责人是否有权对组织内部个人信息处理的不合规操作进行制止和采取必要的纠正措施；
- (六) 个人信息处理者是否公开个人信息保护负责人的联系方式，并将个人信息保护负责人的姓名、联系方式等报送履行个人信息保护职责的部门。

第二十五条对个人信息处理者开展个人信息保护影响评估情况进行审计时，应当重点对影响评估开展情况和评估内容进行审查：

- (一) 是否依照法律、行政法规的规定，在进行对个人权益具有重大影响的个人信息处理活动前通过个人信息保护影响评估；
- (二) 是否对个人处理活动的合法性、正当性和必要性进行了分析评估，是否存在过度收集个人信息的情况；
- (三) 是否对限制个人自主决定权、引发差别性待遇、导致个人名誉受损或者遭受精神压力、造成人身财产受损等安全风险进行了分析评估；
- (四) 是否对所采取的保护措施的合法性、有效性、适应性进行了分析评估；
- (五) 个人信息保护影响评估报告和处理记录是否至少保存三年。

第二十六条个人信息处理者应当制定个人信息安全事件应急预案。审计时，应当对应急预案的全面性、有效性、可执行性作出评价，包括但不限于以下内容：

- (一) 是否结合业务实际，对面临的个人信息安全风险作出了系统评估和预测；
- (二) 指导思想、基本策略，组织机构、人员，技术、物资保障及指挥处置程序、应急和支持措施等是否足以应对预测的风险；
- (三) 是否对相关人员进行应急预案培训，定期对应急预案进行演练。

第二十七条对个人信息处理者个人信息安全事件应急响应处置情况进行评价时，应当重点考虑下列因素：

- (一) 是否按照应急预案、操作规程及时查明个人信息安全事件的影响、范围和可能造成的危害，分析、确定事件发生的原因，提出防止危害扩大的措施方案；
- (二) 是否建立通报渠道，能否在事件发生后72小时内通知履行个人信息保护职责的部门和个人；
- (三) 是否采取相应措施将个人信息安全事件可能造成的损失和可能产生的危害风险降低到最小。

第二十八条大型互联网平台运营者应当成立主要由外部成员组成的独立机构对个人信息保护情况进行监督。审计时，应当对独立机构的独立性、履职能力、监督作用等进行评价。

- (一) 评价独立机构对个人信息保护情况进行监督的独立性，重点审查外部成员与个人信息处理者及其主要股东是否存在可能妨碍其进行独立客观判断的关系；
- (二) 评价外部成员的履职能力，重点审查外部成员是否具备相应的专业知识、能力和经验，能否对个人信息处理者的个人信息保护情况进行监督、指导，发表客观公正的意见建议；
- (三) 评价独立机构的监督作用，重点审查独立机构在个人信息处理者合规制度体系建设、平台规则制定、重大个人信息安全事件处置、督促企业履行社会责任等方面发挥的作用。

第二十九条针对大型互联网平台规则，应当重点审计下列事项：

- (一) 评价平台规则的合法合规性，是否存在与法律、行政法规相抵触的情况；
- (二) 评价平台规则的公平公正性，是否存在恶性竞争、影响消费者权益等违反公平竞争原则、诚实信用原则、公序良俗的内容；
- (三) 评价平台规则个人信息保护条款的有效性，是否合理界定了平台、平台内产品或者服务提供者的个人信息保护权利和义务，是否对平台内经营者处理个人信息行为进行规范，平台内经营者的个人信息保护义务是否明确；
- (四) 检查平台规则的执行情况，通过抽样等方式验证平台规则是否被有效执行。

第三十条大型互联网平台运营者应当对其平台内产品或者服务提供者的个人信息处理活动进行监督。审计时，应当重点审查下列事项：

- （一）是否定期审核平台内产品或者服务提供者个人信息处理规则的合法性、合理性；
- （二）是否定期对平台内产品或者服务提供者处理个人信息遵守法律、行政法规情况进行审核；
- （三）对于严重违法法律、行政法规处理个人信息的产品或者服务提供者，平台是否及时停止向其提供服务。

第三十一条大型互联网平台运营者应当每年发布个人信息保护社会责任报告。审计时，应当重点审查社会责任报告下列内容的披露情况：

- （一）个人信息保护组织架构和内部管理情况；
- （二）个人信息保护能力建设情况；
- （三）个人信息保护措施和成效；
- （四）个人行使权利的申请受理情况；
- （五）独立监督机构履职情况；
- （六）重大个人信息安全事件处理情况；
- （七）法律、行政法规规定的其他情况。